

CS 466: Final Exam

Clean Solution Version

Note. Throughout, let $n = 128$, let 0^n and 1^n denote the all-zero and all-one n -bit strings, and let E_K denote the blockcipher permutation keyed by K . CBC-MAC uses IV 0^n .

Problem 0

Prompt. Write your name and sign below to indicate you followed the UMass Amherst academic honor code in preparing for and taking this exam. Also, write your Spire ID. Without your signature, your exam will not be graded.

Solution. Administrative; no cryptographic solution is required.

Problem 1

Prompt. Define the keyed hash function family

$$H : \{0, 1\}^{128} \times \{0, 1\}^{384} \rightarrow \{0, 1\}^{128}$$

by

$$H_K(M_1 \| M_2 \| M_3) = \text{CBC-MAC}_K(M_1 \| M_2 \| M_3), \quad M_1, M_2, M_3 \in \{0, 1\}^{128}.$$

Show that H is not collision resistant.

Solution. Since this is a keyed hash family in the collision-resistance experiment, the adversary is given K . The adversary can create a collision by changing the first block and compensating in the second block.

Let

$$X = M_1 \| M_2 \| M_3 = 0^n \| 0^n \| 0^n.$$

Choose $M'_1 = 1^n$, and define

$$M'_2 = E_K(M'_1) \oplus E_K(M_1) \oplus M_2, \quad M'_3 = M_3.$$

Output

$$X' = M'_1 \| M'_2 \| M'_3.$$

Clearly $X' \neq X$ because $M'_1 \neq M_1$. Now compare the CBC-MAC computations. For X , let

$$C_1 = E_K(M_1), \quad C_2 = E_K(C_1 \oplus M_2), \quad C_3 = E_K(C_2 \oplus M_3).$$

For X' , the first two chaining values are

$$C'_1 = E_K(M'_1)$$

and

$$C'_2 = E_K(C'_1 \oplus M'_2) = E_K(E_K(M'_1) \oplus E_K(M'_1) \oplus E_K(M_1) \oplus M_2) = E_K(C_1 \oplus M_2) = C_2.$$

Since $M'_3 = M_3$, the final chaining value is also

$$C'_3 = E_K(C'_2 \oplus M'_3) = E_K(C_2 \oplus M_3) = C_3.$$

Therefore

$$H_K(X) = C_3 = C'_3 = H_K(X'),$$

with $X \neq X'$. The adversary uses only a constant number of blockcipher evaluations and succeeds with probability 1.

Problem 2

Prompt. Define $T : \{0, 1\}^{256} \times D \rightarrow \{0, 1\}^{128}$, where D is the set of all bit strings of positive length a multiple of 128, by

$$T_{K_1 \| K_2}(M) = \text{CBC-MAC}_{K_1}(M) \oplus K_2,$$

where $K_1, K_2 \in \{0, 1\}^{128}$.

- **Part A.** What is the difference between T and ECBC-MAC?
- **Part B.** Show that T is not UF-CMA secure.

Solution to Part A. ECBC-MAC first computes the CBC-MAC chaining value with one key, then applies a final independent blockcipher call with another key. That is, ECBC-MAC has the form

$$\text{ECBC}_{K_1, K_2}(M) = E_{K_2}(\text{CBC-MAC}_{K_1}(M)).$$

By contrast, T does not encrypt the final CBC-MAC value under K_2 ; it only xors the final value with K_2 :

$$T_{K_1 \| K_2}(M) = \text{CBC-MAC}_{K_1}(M) \oplus K_2.$$

The final xor is linear, and this linearity enables the forgery below.

Solution to Part B. The adversary makes three MAC queries and then outputs one new valid message-tag pair.

Let $X = 0^n$ and $Y = 1^n$. Query the MAC oracle on the one-block messages X and Y , receiving

$$\tau_X = T(X) = E_{K_1}(X) \oplus K_2, \quad \tau_Y = T(Y) = E_{K_1}(Y) \oplus K_2.$$

Then query the MAC oracle on the two-block message $X \| \tau_X$, receiving

$$\sigma = T(X \| \tau_X).$$

The adversary outputs the forgery

$$(Y \| \tau_Y, \sigma).$$

This message was never queried, since the only queried two-block message was $X \| \tau_X$ and $X \neq Y$.

It remains to verify that the tag is correct. For any one-block message Z , write

$$\tau_Z = T(Z) = E_{K_1}(Z) \oplus K_2.$$

Then the CBC-MAC value of the two-block message $Z\| \tau_Z$ is

$$E_{K_1}(E_{K_1}(Z) \oplus \tau_Z) = E_{K_1}(E_{K_1}(Z) \oplus E_{K_1}(Z) \oplus K_2) = E_{K_1}(K_2).$$

Therefore

$$T(Z\| \tau_Z) = E_{K_1}(K_2) \oplus K_2,$$

which is independent of Z . Hence

$$T(X\| \tau_X) = T(Y\| \tau_Y) = \sigma.$$

So $(Y\| \tau_Y, \sigma)$ is a valid forgery, and the adversary succeeds with probability 1.

Problem 3

Prompt. Let $SE = (\mathcal{K}, \mathcal{E}, \mathcal{D})$ have key-space $\{0, 1\}^{128}$ and message-space $\{0, 1\}^{256}$, with encryption defined as follows:

Algorithm $\mathcal{E}_K(M_1\|M_2)$:
 $r \leftarrow \$\{0, 1\}^{128}$
 $C_1 \leftarrow \text{AES}_K(r) \oplus M_1$
 $C_2 \leftarrow \text{AES}_K(r) \oplus M_2$
 Ret (r, C_1, C_2) .

- **Part A.** Write the decryption algorithm $\mathcal{D}_K$ in pseudocode as above.
- **Part B.** Show that SE is not IND-CPA secure.

Solution to Part A. Decryption recomputes the pad $\text{AES}_K(r)$ and xors it away from both ciphertext blocks:

Algorithm $\mathcal{D}_K(r, C_1, C_2)$:
 $P \leftarrow \text{AES}_K(r)$
 $M_1 \leftarrow C_1 \oplus P$
 $M_2 \leftarrow C_2 \oplus P$
 Ret $M_1\|M_2$.

Correctness is immediate because

$$C_i \oplus \text{AES}_K(r) = (\text{AES}_K(r) \oplus M_i) \oplus \text{AES}_K(r) = M_i$$

for $i \in \{1, 2\}$.

Solution to Part B. The same pad $\text{AES}_K(r)$ is reused on both message blocks, so the ciphertext leaks

$$C_1 \oplus C_2 = (\text{AES}_K(r) \oplus M_1) \oplus (\text{AES}_K(r) \oplus M_2) = M_1 \oplus M_2.$$

An IND-CPA adversary can exploit this leakage perfectly.

The adversary submits the two equal-length challenge messages

$$M^{(0)} = 0^n\|0^n, \quad M^{(1)} = 0^n\|1^n.$$

It receives the challenge ciphertext (r, C_1, C_2) . If $C_1 = C_2$, it outputs 0; otherwise it outputs 1.

If the challenger encrypted $M^{(0)}$, then $M_1 \oplus M_2 = 0^n$, so $C_1 \oplus C_2 = 0^n$ and $C_1 = C_2$. If the challenger encrypted $M^{(1)}$, then $M_1 \oplus M_2 = 1^n$, so $C_1 \oplus C_2 = 1^n$ and $C_1 \neq C_2$. The adversary guesses the challenge bit correctly with probability 1, so the scheme is not IND-CPA secure.

Problem 4

Prompt. Recall that the Davies-Meyer construction builds a compression function h from a blockcipher E by

$$h(c, m) = E_m(c) \oplus c.$$

Part A. Briefly explain why a realistic adversary, e.g. a well-funded organization or nation-state, can find collisions in the resulting compression function h when E is AES.

Bonus. Why does not the same attack contradict the security of AES as a PRF?

Part B. For each statement below, circle T or F. No justification is required.

1. Every function family that is PRF-secure is subject to a birthday attack.
2. Plain CBC-MAC is UF-CMA secure on variable-length messages. You can assume the message length is always a multiple of the block length.
3. An encryption scheme whose message-space consists of exactly two messages of different lengths and whose encryption algorithm is deterministic cannot be IND-CPA secure.
4. Encrypt-then-MAC produces a secure authenticated encryption scheme for any IND-CPA secure symmetric encryption scheme and any PRF-secure MAC.
5. If H is a hash function built using the Merkle-Damgard transform, then the function family $I_K(M) = H(K\|M)$ where K is one block is a UF-CMA secure MAC.

Solution to Part A. With AES, the output of h is only 128 bits. An adversary can sample many distinct pairs (c_i, m_i) and compute

$$y_i = h(c_i, m_i) = \text{AES}_{m_i}(c_i) \oplus c_i.$$

By the birthday paradox, after about 2^{64} such evaluations, the adversary has a good chance of finding two distinct inputs $(c_i, m_i) \neq (c_j, m_j)$ such that

$$h(c_i, m_i) = h(c_j, m_j).$$

Thus the compression function has only birthday-bound collision resistance, about 2^{64} work, rather than 2^{128} work. This is very expensive but can be within the conceptual reach of a very well-funded adversary.

Bonus solution. This does not contradict the security of AES as a PRF for two reasons. First, the Davies-Meyer attack varies the AES key m as part of the input to h , while the AES PRF experiment uses one fixed secret key and only lets the adversary choose inputs to AES under that key. Second, birthday collisions are expected for a random 128-bit-output function as well; merely finding such a collision in the compression function does not by itself distinguish AES from an ideal primitive in the PRF sense.

Solution to Part B.

1. **F.** A PRP-style PRF-secure family can have no output collisions for a fixed key.
2. **F.** Plain CBC-MAC is not secure for variable-length messages.
3. **F.** IND-CPA challenge messages must have equal length; with only two different-length messages, the usual attack is not available.

4. **T.** Encrypt-then-MAC with IND-CPA encryption and a PRF-secure MAC gives secure authenticated encryption.
5. **F.** Prefix MAC with Merkle-Damgard is vulnerable to length extension.